Fingerprinting et reconnaissance

2 JANVIER

Efrei Paris
Créé par NANA Brandon | B2 ICS

Avant-propos

Ce rapport a été rédigé dans un objectif pédagogique et professionnel, afin de documenter un exercice de fingerprinting/reconnaissance d'un serveur web et d'en restituer les résultats de manière claire, structurée et reproductible.
Il s'appuie sur les consignes du TP (collecte d'informations, utilisation d'outils de reconnaissance, mise en évidence des éléments exposés et des contre-mesures) ainsi que sur une structure de rapport de type "penetration test report" (confidentialité, périmètre, approche, résultats, recommandations, annexes).
Les captures et sorties d'outils associées (annexes) servent de preuves et permettent de justifier les constats techniques présentés dans le document.

Avertissement

Le fingerprinting, les scans réseau et toute activité de reconnaissance sur un système sans autorisation explicite sont illégaux ; l'exercice décrit ici est limité au cadre autorisé du TP (systèmes appartenant à l'étudiant/à l'environnement de formation).
Les informations contenues dans ce document sont confidentielles et destinées uniquement au contexte prévu (formation/évaluation) ; elles ne doivent pas être diffusées à des tiers sans accord explicite.
Ce rapport ne constitue pas un avis juridique, et les éléments techniques sont fournis pour décrire les observations et favoriser la remédiation/durcissement, pas pour faciliter un usage malveillant.

Introduction

Ce rapport présente les résultats d'un exercice de fingerprinting et de reconnaissance d'un serveur web, visant à identifier les caractéristiques techniques exposées (système d'exploitation, ports/services, versions logicielles, technologies web, en-têtes HTTP, configuration TLS, etc.) afin d'évaluer la surface d'attaque et le niveau d'exposition.
Les travaux s'inscrivent dans une démarche d'« intelligence gathering » (collecte d'informations) et s'appuient sur des techniques actives (ex. scans et requêtes) et passives, conformément aux objectifs pédagogiques du TP (maîtrise de Nmap/Netcat/WhatWeb, évaluation des contre-mesures, production d'un rapport).
Le périmètre de test se limite strictement aux systèmes explicitement autorisés dans le cadre du TP, conformément au rappel légal/éthique (le fingerprinting sans autorisation est illégal et

une autorisation écrite est requise en contexte réel).

Table des matières

Avant-propos 2

Avertissement 2

Introduction 2

Résumé exécutif. 5

3.2. Synthèse des informations découvertes et niveau d'exposition. 5

Approche et méthodologie. 6

Hypothèses, limites et conditions de réalisation du test. 6

Outils et techniques utilisés (Nmap, Netcat, curl, WhatWeb, etc.). 6

Périmètre du test (systèmes, adresses IP et services inclus/exclus). 7

Résultats détaillés. 7

5.1. OS fingerprinting (identification du système d'exploitation). (annexe 1) 7

5.2. Découverte des ports et services (ports ouverts, services associés). (annexe 1) 8

5.3. Détection des versions et banner grabbing (services réseau et HTTP). (annexe 2) 8

5.4. Analyse des en-têtes HTTP et des informations révélées. (annexe 3) 8

En-têtes observés 9

5.5 Analyse TLS/SSL (certificat, protocoles et suites cryptographiques) (annexe 4) .. 9

Certificat observé 9

Protocoles et suites 10

5.6. Web application fingerprinting (serveur web, langage, CMS, frameworks, fichiers/répertoires exposés). (annexe 5) 10

Serveur web et OS "déduit" 10

Langage, CMS, frameworks 11

Fichiers/répertoires exposés (tests) 11

Tableau comparatif avant / après sécurisation (TP4). 12

Recommandations. 12
Réduction surface d'attaque 12
Durcissement HTTP/Apache 12
En-têtes de sécurité 13
TLS/SSL 13
Contenus et répertoires exposés 13
Actions à court terme. (0 à 7 jours) 13
Actions à moyen terme. (1 à 4 semaines) 14
Actions à long terme. 14
Annexes 15
Annexe 1 15

Résumé exécutif.

Ce rapport présente les résultats d'un test de fingerprinting/reconnaissance réalisé sur un serveur web dans le cadre d'un TP, avec pour finalité d'identifier les informations techniques exposées et d'apprécier l'efficacité des mesures de durcissement déjà mises en place.
Les constats sont basés sur des activités de découverte et d'énumération (sans exploitation), et sont documentés de manière à être reproductibles grâce aux preuves et sorties d'outils fournies en annexe.

3.1. Contexte et objectifs du test de fingerprinting.

L'exercice s'inscrit dans la phase de collecte d'informations (reconnaissance) et vise à identifier les caractéristiques d'un système cible telles que l'OS, les ports/services, les versions, les technologies web, les en-têtes HTTP et la configuration TLS.
Les objectifs pédagogiques incluent la maîtrise d'outils de reconnaissance (ex. Nmap, Netcat, WhatWeb, curl), et l'évaluation des contre-mesures déployées lors d'un TP précédent via une comparaison avant/après sécurisation.
Le test est réalisé exclusivement sur un périmètre autorisé dans le cadre du TP, le fingerprinting sur des systèmes sans autorisation étant rappelé comme illégal hors cadre contractualisé.

3.2. Synthèse des informations découvertes et niveau d'exposition.

Les résultats de scan indiquent une exposition réseau limitée aux services web, avec les ports 80 (HTTP) et 443 (HTTPS) identifiés comme ouverts sur la cible testée.
La détection de services met en évidence un serveur Apache httpd en version 2.4.58 sur Ubuntu, avec redirection HTTP vers HTTPS, ainsi que des informations TLS (certificat « localhost » auto-signé observé et prise en charge de suites de chiffrement TLS) récupérables via l'énumération SSL/TLS.
Au niveau applicatif, l'empreinte technologique et les en-têtes HTTP observés révèlent plusieurs en-têtes de sécurité (ex. X-Frame-Options, X-XSS-Protection, X-Content-Type-Options, Referrer-Policy, Content-Security-Policy, Permissions-Policy), ce qui suggère un durcissement partiel, mais l'exposition d'informations de bannière (ex. en-tête Server/version) demeure un vecteur de renseignement utile à un attaquant pour cibler des faiblesses connues ou des erreurs de configuration.

Approche et méthodologie.

L'évaluation a été conduite comme un exercice de reconnaissance/fingerprinting visant à identifier la surface d'attaque et les informations techniques exposées (OS, ports/services, versions, technologies web, en-têtes HTTP, TLS), sans viser l'exploitation de vulnérabilités.
La restitution privilégie une démarche reproductible, en s'appuyant sur des commandes traçables et des preuves (captures/sorties) conservées en annexe, conformément aux attendus d'un rapport professionnel.

Hypothèses, limites et conditions de réalisation du test.

Autorisation : le test est réalisé uniquement sur l'environnement explicitement autorisé du TP (serveur contrôlé par l'étudiant), conformément au rappel légal/éthique.
Limites : la reconnaissance se limite à l'identification/énumération (information gathering) et à la vérification de contre-mesures, sans actions intrusives de type exploitation, élévation de privilèges ou altération de données.
Conditions : les mesures de sécurisation mises en place précédemment (ex. en-têtes de sécurité HTTP, durcissement, WAF/ModSecurity selon configuration) sont prises en compte via une comparaison "avant/après".

Outils et techniques utilisés (Nmap, Netcat, curl, WhatWeb, etc.).

- Nmap : découverte d'hôtes/ports, détection de versions, fingerprint OS et scripts NSE orientés web/SSL (ex. http-headers/http-title, ssl-enum-ciphers, ssl-cert).

- Netcat : banner grabbing et vérification manuelle de bannières de services (HTTP/SSH, etc.) lorsque pertinent.
- curl / OpenSSL : récupération et analyse des en-têtes HTTP, redirections, et informations de certificat TLS en mode verbeux.
- WhatWeb / Wappalyzer : empreinte technologique applicative (serveur web, OS probable, frameworks/technos détectables) côté HTTP/HTTPS.
- Énumération web : tests de fichiers “standards” (robots.txt, sitemap.xml, phpinfo.php, server-status…) et brute-force de répertoires (Gobuster) si applicable.

Périmètre du test (systèmes, adresses IP et services inclus/exclus).

Actifs inclus : serveur web de test identifié sur le réseau local, IP observée 192.168.142.135.
Services inclus : services exposés par la cible et nécessaires au TP, notamment HTTP/HTTPS (ports 80 et 443 observés ouverts), ainsi que la collecte d’indices de configuration associée (bannières, en-têtes, TLS).
Exclus : tout système tiers/hors environnement TP, ainsi que toute action dépassant la reconnaissance (exploitation, déni de service, persistance, mouvement latéral), conformément au cadre légal et pédagogique.

Résultats détaillés.

5.1. OS fingerprinting (identification du système d’exploitation). (annexe 1)

L’identification du système d’exploitation a été réalisée via Nmap en mode OS detection (option -O, nécessitant des privilèges élevés), afin d’estimer l’OS de la cible à partir de signatures réseau (comportements TCP/IP).
Sur la cible 192.168.142.135, Nmap indique un système Linux avec une estimation de noyau “Linux 4.X–5.X”, et propose également des correspondances possibles de type “MikroTik RouterOS 7.X”, avec une distance réseau de 1 saut (Network Distance: 1 hop).
Ces résultats restent probabilistes (fingerprinting), mais ils fournissent un indicateur exploitable pour orienter la suite de la reconnaissance (choix d’outils, vecteurs d’attaque plausibles, recherche de vulnérabilités par version/plateforme).

5.2. Découverte des ports et services (ports ouverts, services associés). (annexe 1)

La phase de découverte a consisté à identifier les ports TCP accessibles depuis la machine d'audit vers la cible 192.168.142.135, afin de recenser les services exposés et de délimiter la surface d'attaque.
Les résultats montrent que la cible est joignable ("Host is up") et que seuls les ports 80/tcp (HTTP) et 443/tcp (HTTPS) apparaissent ouverts lors d'un scan standard, les autres ports testés étant fermés (ex. 8080/8443 en "closed").
Cette exposition concentrée sur HTTP/HTTPS indique que l'effort de reconnaissance et d'analyse doit se focaliser sur la pile web (serveur web, configuration TLS, en-têtes HTTP, contenus et répertoires accessibles).

5.3. Détection des versions et banner grabbing (services réseau et HTTP). (annexe 2)

Après l'identification des ports ouverts, une détection de versions a été réalisée afin d'associer chaque service exposé à un produit/une version, information utile pour l'évaluation du niveau d'exposition (recherche de CVE, erreurs de configuration, surface d'attaque applicative).
Le scan nmap -sV met en évidence, sur les ports 80 et 443, un serveur Apache httpd 2.4.58, le port 443 étant identifié comme ssl/http (HTTPS).
En complément, le banner grabbing (notamment via Netcat et la récupération d'en-têtes HTTP) confirme la bannière Server: Apache2/2.4.58 (Ubuntu) et permet également d'observer des éléments de comportement (ex. réponse HTTP 400 lors d'une requête incomplète, redirection HTTP→HTTPS, etc.).

5.4. Analyse des en-têtes HTTP et des informations révélées. (annexe 3)

L'analyse des en-têtes HTTP vise à identifier les informations divulguées par le serveur (bannières, redirections, métadonnées) et à vérifier la présence d'en-têtes de sécurité côté HTTP/HTTPS.
Sur la cible 192.168.142.135, les réponses HTTP révèlent notamment la bannière Server: Apache2.4.58 Ubuntu, ce qui expose la technologie et la version du serveur web.
Les réponses montrent aussi une redirection vers HTTPS (en-tête Location:

https://localhost / httpslocalhost selon la sortie), ce qui confirme un comportement de forçage/transition HTTP → HTTPS.

En-têtes observés

Les en-têtes de sécurité suivants apparaissent dans les réponses (HTTP 302 et HTTPS 200/403 selon le cas) : X-Frame-Options: SAMEORIGIN, X-XSS-Protection: 1; mode=block, X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, Content-Security-Policy: default-src 'self' ..., et Permissions-Policy: geolocation, microphone, camera.
Ces éléments indiquent une volonté de réduire certains risques côté navigateur (clickjacking, sniffing MIME, politique de référent, CSP, restrictions d'API).
Un test de type grep -i x-powered-by sur les en-têtes ne remonte rien dans la sortie fournie, suggérant que l'en-tête X-Powered-By n'est pas exposé (ou pas dans ce contexte de réponse).

5.5 Analyse TLS/SSL (certificat, protocoles et suites cryptographiques) (annexe 4)

L'analyse TLS/SSL a été réalisée sur le service HTTPS (port 443) afin d'extraire les informations du certificat X.509, d'identifier les versions de protocoles supportées et d'inventorier les suites cryptographiques (ciphers) négociables.
Les résultats confirment la présence d'un certificat TLS pour CN=localhost, auto-signé (issuer identique au subject), avec une clé publique RSA 2048 bits et une période de validité indiquée (Not valid before / Not valid after).
Les scripts Nmap dédiés (ssl-cert, ssl-enum-ciphers) montrent que le service supporte au moins TLS 1.2 et TLS 1.3 et listent de nombreuses suites (ECDHE/DHE/RSA) avec un niveau de notation "A" dans la sortie fournie.

Certificat observé

Le scan met en évidence un certificat dont le Subject comporte CN=localhost (avec des champs organisation/ville/pays renseignés) et une signature en sha256WithRSAEncryption.
La clé publique est de type RSA 2048 bits et la validité affichée couvre approximativement une année (de fin 2025 à fin 2026 dans la capture).

La vérification signale un certificat auto-signé (ex. “self-signed certificate” / code de vérification associé), ce qui est cohérent avec un environnement de lab ou un service non exposé publiquement.

Protocoles et suites

La sortie ssl-enum-ciphers indique explicitement la prise en charge de TLSv1.2 (liste de suites) et de TLSv1.3 (suites modernes de type AES-GCM/ChaCha20-Poly1305 dans la sortie).
Les suites affichées incluent des familles ECDHE/DHE et RSA, avec des paramètres de DH 2048 bits et des courbes ECC (ex. secp256r1 / x25519 selon la sortie).
Ces informations permettent d’évaluer rapidement si des protocoles obsolètes (TLS 1.0/1.1) ou des chiffrements faibles sont acceptés (non observés dans l’extrait fourni).

5.6. Web application fingerprinting (serveur web, langage, CMS, frameworks, fichiers/répertoires exposés). (annexe 5)

Le web application fingerprinting a été mené pour identifier la pile technologique exposée par l’application (serveur web, OS déduit, technologies applicatives éventuelles) et repérer des chemins/fichiers “standards” pouvant divulguer des informations ou être mal configurés.
Les outils orientés reconnaissance web (WhatWeb, extension Wappalyzer) et des requêtes HTTP ciblées (curl) ont été utilisés afin de recouper les informations issues des en-têtes, des redirections et des pages accessibles.
Un début d’énumération de répertoires a également été tenté (Gobuster), afin de détecter d’éventuels endpoints connus ou ressources oubliées.

Serveur web et OS “déduit”

WhatWeb identifie un serveur Apache 2.4.58 et indique également “Ubuntu Linux” via la chaîne serveur/en-têtes, avec une redirection vers HTTPS (RedirectLocation).
Wappalyzer confirme la présence d’Apache HTTP Server et d’Ubuntu, et l’accès au site expose la page par défaut Apache (“It works!”), typique d’une installation Apache fonctionnelle avec la page de test.
Ces éléments confirment un socle applicatif centré sur Apache sous Ubuntu, ce qui oriente la

recherche vers la configuration Apache/TLS et l'exposition applicative (virtual hosts, répertoires web, règles de sécurité HTTP).

Langage, CMS, frameworks

Dans les sorties fournies, aucune détection explicite d'un CMS (WordPress/Drupal/Joomla) ni d'un framework applicatif (Laravel/Symfony/Django, etc.) n'apparaît dans les résultats WhatWeb/Wappalyzer affichés.
Un tableau récapitulatif mentionne un en-tête X-Powered-By: PHP/8.1.2 "avant TP4", mais indique qu'il n'est pas visible dans les tests/extraits fournis après modification (pas d'extrait remontrant X-Powered-By).
En l'état, l'empreinte la plus fiable reste donc : Apache 2.4.58 sur Ubuntu, sans preuve robuste d'un CMS/framework côté applicatif dans les captures.

Fichiers/répertoires exposés (tests)

Des tests "fichiers classiques" ont été effectués
(ex. robots.txt, sitemap.xml, .htaccess, phpinfo.php, server-status) et renvoient un
code 301 dans les commandes affichées, ce qui suggère surtout une redirection
(probablement HTTP → HTTPS) plutôt qu'un accès direct au contenu sur HTTP.
L'énumération par Gobuster a rencontré une difficulté : le serveur renvoie un statut identique pour des ressources inexistantes (message indiquant que le status code correspond à l'option "Negative Status codes"), ce qui empêche l'outil de distinguer facilement les chemins valides sans ajuster les paramètres (exclusion par code/longueur).
Ce comportement implique que l'énumération doit être adaptée (exclure le code concerné ou filtrer par longueur de réponse) pour produire une liste fiable de répertoires/fichiers accessibles.

Tableau comparatif avant / après sécurisation (TP4).

Information	Avant TP4	Après TP4
En-tête Server	Apache/2.4.52 (Ubuntu) `ppl-ai-file-upload.s3.am`	Apache/2.4.58 (Ubuntu) `ppl-ai-file-upload.s3.am`
En-tête X-Powered-By	PHP/8.1.2 `ppl-ai-file-upload.s3.am`	Non visible dans les tests fournis (pas d'extrait montrant `X-Powered-By`). `ppl-ai-file-upload.s3.am`
OS détecté (Nmap)	Linux 5.x `ppl-ai-file-upload.s3.am`	Non visible dans les tests fournis. `ppl-ai-file-upload.s3.am`
WAF détecté	Non `ppl-ai-file-upload.s3.am`	Non visible dans la sortie fournie (le scan affiché ne montre pas de WAF). `ppl-ai-file-upload.s3.am`
En-têtes de sécurité	Absents `ppl-ai-file-upload.s3.am`	Présents : `X-Frame-Options: SAMEORIGIN`, `X-XSS-Protection: 1; mode=block`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`. `ppl-ai-file-upload.s3.am`

Recommandations.

Les recommandations ci-dessous visent à réduire la surface d'attaque observée (services web exposés, divulgation de bannières, configuration TLS et comportements applicatifs) et à améliorer le niveau de durcissement global.

Réduction surface d'attaque

Filtrer strictement les flux entrants au pare-feu (n'autoriser que les ports indispensables, idéalement 80/443 uniquement si c'est le besoin).
Mettre en place une segmentation réseau (VLAN/ACL) et limiter l'exposition du serveur aux seules sources attendues (ex. reverse proxy, VPN d'administration).

Durcissement HTTP/Apache

Réduire la fuite d'information : désactiver/limiter l'affichage des versions (ex. ServerTokens Prod, ServerSignature Off) et éviter d'exposer des bannières détaillées.

Supprimer/neutraliser la page par défaut ("It works!") et tout contenu de test afin d'éviter d'indiquer qu'il s'agit d'une installation standard.
Vérifier la cohérence des redirections (en-tête Location) pour pointer vers le nom DNS attendu (éviter des redirections vers localhost côté client).

En-têtes de sécurité

Conserver les en-têtes déjà présents et compléter avec HSTS (Strict-Transport-Security) une fois HTTPS généralisé et stable.
Revoir la Content-Security-Policy pour qu'elle soit la plus restrictive possible (réduire unsafe-inline si présent, limiter les sources, etc.).
Ajouter/valider X-Frame-Options (ou frame-ancestors CSP), Referrer-Policy, Permissions-Policy, et vérifier leur homogénéité sur toutes les routes (200/302/403).

TLS/SSL

Remplacer le certificat auto-signé par un certificat émis par une autorité reconnue (ou une PKI interne) et aligner le CN/SAN sur le nom DNS réel du service.
Désactiver les protocoles obsolètes si activés (TLS 1.0/1.1) et privilégier TLS 1.3 puis TLS 1.2 avec suites robustes uniquement (priorité ECDHE, interdiction des chiffrements faibles).
Activer OCSP stapling et mettre en place une rotation/renouvellement automatisé des certificats.

Contenus et répertoires exposés

Vérifier et restreindre l'accès aux endpoints sensibles (ex. server-status, pages d'admin, diagnostics type phpinfo.php) via ACL/IP allowlist et authentification forte.
Désactiver l'indexation de répertoires, appliquer le principe du moindre privilège sur /var/www/ (droits fichiers) et s'assurer qu'aucun fichier de configuration n'est accessible depuis le web.
Normaliser la gestion des erreurs (codes HTTP cohérents, pages d'erreur non bavardes) pour limiter la fuite d'indices tout en conservant une observabilité correcte côté logs.

Actions à court terme. (0 à 7 jours)

- Corriger la redirection HTTP→HTTPS pour qu'elle pointe vers le FQDN/IP attendu (et pas localhost) afin d'éviter un comportement incohérent côté client.

- Retirer la page par défaut Apache (“It works!”) et tout contenu de test pour limiter l’empreinte triviale et les erreurs de configuration.
- Réduire la fuite d’information côté Apache : désactiver l’affichage des versions (ex. paramètres équivalents à ServerTokens/ServerSignature).
- Restreindre l’accès aux URLs sensibles potentielles (ex. server-status, phpinfo.php si présent) via contrôle d’accès (IP allowlist / authentification) et vérifier qu’elles ne sont pas servies.
- Vérifier rapidement la politique TLS : conserver TLS 1.3/1.2 et s’assurer que les protocoles obsolètes ne sont pas activés (si ce point n’a pas été testé explicitement, le valider).

Actions à moyen terme. (1 à 4 semaines)

- Remplacer le certificat auto-signé par un certificat émis par une autorité de confiance (publique ou PKI interne) avec CN/SAN alignés sur le nom réel du service.
- Revoir et durcir les en-têtes de sécurité déjà présents (CSP, Permissions-Policy, etc.) et uniformiser leur présence sur toutes les réponses (200/302/403) observées.
- Mettre en place une configuration TLS “propre” : supprimer les suites non nécessaires, privilégier des suites modernes et documenter la politique de chiffrement.
- Réaliser une revue de configuration Apache (vhosts, permissions, modules) pour réduire la surface d’attaque et éviter l’exposition involontaire de répertoires/fichiers.

Actions à long terme.

- Industrialiser la gestion des certificats (renouvellement automatique, procédures de rotation, surveillance d’expiration) et standardiser l’architecture (reverse proxy/WAF si besoin).
- Mettre en place une supervision et des alertes : logs centralisés, détection de scans, suivi des erreurs 4xx/5xx, et corrélation basique des événements de sécurité.
- Instaurer un cycle de patching/upgrade régulier (OS + Apache/OpenSSL) pour éviter de rester durablement sur des versions identifiables publiquement via les bannières.
- Ajouter des contrôles de sécurité récurrents (scan de configuration TLS, contrôle des en-têtes, vérification d’exposition de chemins standards) intégrés à une routine de validation.

Annexes

Annexe 1

```
brandon@brandon:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN
 group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel
 state UP group default qlen 1000
    link/ether 00:0c:29:65:31:05 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.142.135/24 brd 192.168.142.255 scope global dynami
c noprefixroute ens33
       valid_lft 1728sec preferred_lft 1728sec
    inet6 fe80::20c:29ff:fe65:3105/64 scope link
       valid_lft forever preferred_lft forever
brandon@brandon:~$
```

```
┌──(brandon㉿kali)-[~]
└─$ nmap 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:31 CET
Nmap scan report for 192.168.142.135
Host is up (0.00039s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds

┌──(brandon㉿kali)-[~]
└─$
```

```
┌──(brandon㉿kali)-[~]
└─$ nmap -p- 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:33 CET
Nmap scan report for 192.168.142.135
Host is up (0.00094s latency).
Not shown: 65533 closed tcp ports (reset)
PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 3.15 seconds

┌──(brandon㉿kali)-[~]
└─$ nmap -p 80,443,8080,8443 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:33 CET
Nmap scan report for 192.168.142.135
Host is up (0.0016s latency).

PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
8080/tcp closed http-proxy
8443/tcp closed https-alt
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds
```

```
┌──(brandon㉿kali)-[~]
└─$ nmap -sV 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:36 CET
Nmap scan report for 192.168.142.135
Host is up (0.00079s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 2.4.58
443/tcp open  ssl/http Apache httpd 2.4.58
MAC Address: 00:0C:29:65:31:05 (VMware)
Service Info: Host: localhost

Service detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds
```

```
┌──(brandon㉿kali)-[~]
└─$ nmap -sV -T5 -A 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:39 CET
Nmap scan report for 192.168.142.135
Host is up (0.0012s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 2.4.58
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Did not follow redirect to https://localhost/
443/tcp open  ssl/http Apache httpd 2.4.58
|_http-title: 403 Forbidden
| tls-alpn:
|_  http/1.1
| ssl-cert: Subject: commonName=localhost/organizationName=Efrei/stateOrProvinceNa
me=Paris/countryName=FR
| Not valid before: 2025-12-26T14:33:27
|_Not valid after:  2026-12-26T14:33:27
|_ssl-date: TLS randomness does not represent time
|_http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 00:0C:29:65:31:05 (VMware)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:ro
uteros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: Host: localhost

TRACEROUTE
HOP RTT     ADDRESS
1   1.24 ms 192.168.142.135

OS and Service detection performed. Please report any incorrect results at https:/
/nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.63 seconds
```

Annexe 2

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ sudo nmap -A -oN scan_results.txt 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:43 CET
Nmap scan report for 192.168.142.135
Host is up (0.0015s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 2.4.58
|_http-title: Did not follow redirect to https://localhost/
|_http-server-header: Apache/2.4.58 (Ubuntu)
443/tcp open  ssl/http Apache httpd 2.4.58
| ssl-cert: Subject: commonName=localhost/organizationName=Efrei/stateOrProvinceNa
me=Paris/countryName=FR
| Not valid before: 2025-12-26T14:33:27
|_Not valid after:  2026-12-26T14:33:27
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: 403 Forbidden
|_ssl-date: TLS randomness does not represent time
| tls-alpn:
|_  http/1.1
MAC Address: 00:0C:29:65:31:05 (VMware)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:ro
uteros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: Host: localhost

TRACEROUTE
HOP RTT     ADDRESS
1   1.49 ms 192.168.142.135

OS and Service detection performed. Please report any incorrect results at https:/
/nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.48 seconds
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ cat scan_results.txt
# Nmap 7.95 scan initiated Sat Dec 27 11:43:45 2025 as: /usr/lib/nmap/nmap -A -oN
scan_results.txt 192.168.142.135
Nmap scan report for 192.168.142.135
Host is up (0.0015s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 2.4.58
|_http-title: Did not follow redirect to https://localhost/
|_http-server-header: Apache/2.4.58 (Ubuntu)
443/tcp open  ssl/http Apache httpd 2.4.58
| ssl-cert: Subject: commonName=localhost/organizationName=Efrei/stateOrProvinceNa
me=Paris/countryName=FR
| Not valid before: 2025-12-26T14:33:27
|_Not valid after:  2026-12-26T14:33:27
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: 403 Forbidden
|_ssl-date: TLS randomness does not represent time
| tls-alpn:
|_  http/1.1
MAC Address: 00:0C:29:65:31:05 (VMware)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:ro
uteros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: Host: localhost

TRACEROUTE
HOP RTT     ADDRESS
1   1.49 ms 192.168.142.135

OS and Service detection performed. Please report any incorrect results at https:/
/nmap.org/submit/ .
# Nmap done at Sat Dec 27 11:44:01 2025 -- 1 IP address (1 host up) scanned in 15.
48 seconds

┌──(brandon㉿kali)-[~/Bureau]
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ nmap --script http-enum,http-headers,http-title -p 80,443 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:46 CET
Nmap scan report for 192.168.142.135
Host is up (0.0013s latency).

PORT    STATE SERVICE
80/tcp  open  http
|_http-title: Did not follow redirect to https://localhost/
| http-headers:
|   Date: Sat, 27 Dec 2025 10:46:18 GMT
|   Server: Apache/2.4.58 (Ubuntu)
|   X-Frame-Options: SAMEORIGIN
|   X-XSS-Protection: 1; mode=block
|   X-Content-Type-Options: nosniff
|   Referrer-Policy: strict-origin-when-cross-origin
|   Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'sel
f' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-ancestors 'self';
 form-action 'self'
|   Permissions-Policy: geolocation=(), microphone=(), camera=()
|   Location: https://localhost/
|   Content-Length: 283
|   Connection: close
|   Content-Type: text/html; charset=iso-8859-1
|
|_  (Request type: GET)
443/tcp open  https
|_http-title: 403 Forbidden
| http-headers:
|   Date: Sat, 27 Dec 2025 10:46:18 GMT
|   Server: Apache/2.4.58 (Ubuntu)
|   X-Frame-Options: SAMEORIGIN
|   X-XSS-Protection: 1; mode=block
|   X-Content-Type-Options: nosniff
|   Referrer-Policy: strict-origin-when-cross-origin
|   Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'sel
f' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-ancestors 'self';
 form-action 'self'
|   Permissions-Policy: geolocation=(), microphone=(), camera=()
|   Content-Length: 281
|   Connection: close
|   Content-Type: text/html; charset=iso-8859-1
|
|_  (Request type: GET)
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 8.16 seconds
```

```
brandon@kali: ~/Bureau
Fichier  Actions  Éditer  Vue  Aide

┌──(brandon㉿kali)-[~/Bureau]
└─$ nmap --script http-waf-detect,http-waf-fingerprint -p 80,443 192.168
.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:48 CET
Nmap scan report for 192.168.142.135
Host is up (0.0011s latency).

PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.43 seconds

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ nmap --script ssl-enum-ciphers,ssl-cert -p 443 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:49 CET
Nmap scan report for 192.168.142.135
Host is up (0.00085s latency).

PORT    STATE SERVICE
443/tcp open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_CCM (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_CCM_8 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CCM (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CCM_8 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_ARIA_128_GCM_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_ARIA_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (dh 2048) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_256_GCM_SHA384 (rsa 2048) - A
```

```
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_256_CBC_SHA256 (rsa 2048) - A
|     compressors:
|       NULL
|     cipher preference: client
|   TLSv1.3:
|     ciphers:
|       TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|       TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|     cipher preference: client
|_  least strength: A
| ssl-cert: Subject: commonName=localhost/organizationName=Efrei/stateOr
ProvinceName=Paris/countryName=FR
| Issuer: commonName=localhost/organizationName=Efrei/stateOrProvinceNam
e=Paris/countryName=FR
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-12-26T14:33:27
| Not valid after:  2026-12-26T14:33:27
| MD5:   144e:1b5b:f54d:4e6c:e387:4ef3:a5aa:254f
|_SHA-1: adae:2e91:192b:e7e8:1a66:c7f4:f461:6611:4519:d6de
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ nc 192.168.142.135 80
HEAD / HTTP/1.1
HTTP/1.1 400 Bad Request
Date: Sat, 27 Dec 2025 10:52:36 GMT
Server: Apache/2.4.58 (Ubuntu)
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self'; script-src 'self'; style-sr
c 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-a
ncestors 'self'; form-action 'self'
Permissions-Policy: geolocation=(), microphone=(), camera=()
Content-Length: 301
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br
 />
</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at localhost Port 80</address>
</body></html>

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ nc 192.168.142.135 22
SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.14
```

Annexe 3

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -I http://192.168.142.135
HTTP/1.1 302 Found
Date: Sat, 27 Dec 2025 11:04:11 GMT
Server: Apache/2.4.58 (Ubuntu)
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self'; script-src 'self'; style-sr
c 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-a
ncestors 'self'; form-action 'self'
Permissions-Policy: geolocation=(), microphone=(), camera=()
Location: https://localhost/
Content-Type: text/html; charset=iso-8859-1


┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ nmap --script http-enum,http-headers,http-title -p 80,443 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 11:46 CET
Nmap scan report for 192.168.142.135
Host is up (0.0013s latency).

PORT    STATE SERVICE
80/tcp  open  http
|_http-title: Did not follow redirect to https://localhost/
| http-headers:
|   Date: Sat, 27 Dec 2025 10:46:18 GMT
|   Server: Apache/2.4.58 (Ubuntu)
|   X-Frame-Options: SAMEORIGIN
|   X-XSS-Protection: 1; mode=block
|   X-Content-Type-Options: nosniff
|   Referrer-Policy: strict-origin-when-cross-origin
|   Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'sel
f' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-ancestors 'self';
 form-action 'self'
|   Permissions-Policy: geolocation=(), microphone=(), camera=()
|   Location: https://localhost/
|   Content-Length: 283
|   Connection: close
|   Content-Type: text/html; charset=iso-8859-1
|
|_  (Request type: GET)
443/tcp open  https
|_http-title: 403 Forbidden
| http-headers:
|   Date: Sat, 27 Dec 2025 10:46:18 GMT
|   Server: Apache/2.4.58 (Ubuntu)
|   X-Frame-Options: SAMEORIGIN
|   X-XSS-Protection: 1; mode=block
|   X-Content-Type-Options: nosniff
|   Referrer-Policy: strict-origin-when-cross-origin
|   Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'sel
f' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-ancestors 'self';
 form-action 'self'
|   Permissions-Policy: geolocation=(), microphone=(), camera=()
|   Content-Length: 281
|   Connection: close
|   Content-Type: text/html; charset=iso-8859-1
|
|_  (Request type: GET)
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 8.16 seconds
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -I http://192.168.142.135
HTTP/1.1 302 Found
Date: Sat, 27 Dec 2025 11:04:11 GMT
Server: Apache/2.4.58 (Ubuntu)
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self'; script-src 'self'; style-sr
c 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-a
ncestors 'self'; form-action 'self'
Permissions-Policy: geolocation=(), microphone=(), camera=()
Location: https://localhost/
Content-Type: text/html; charset=iso-8859-1


┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -I -k https://192.168.142.135
HTTP/1.1 200 OK
Date: Sat, 27 Dec 2025 11:04:34 GMT
Server: Apache/2.4.58 (Ubuntu)
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self'; script-src 'self'; style-sr
c 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self'; frame-a
ncestors 'self'; form-action 'self'
Permissions-Policy: geolocation=(), microphone=(), camera=()
Last-Modified: Fri, 26 Dec 2025 13:41:38 GMT
ETag: "29af-646db0d85d3fd"
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html
```

Annexe 4

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ openssl s_client -connect 192.168.142.135:443 < /dev/null 2>/dev/nul
l
CONNECTED(00000003)
---
Certificate chain
 0 s:C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
   i:C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
   a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
   v:NotBefore: Dec 26 14:33:27 2025 GMT; NotAfter: Dec 26 14:33:27 2026
 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIDsTCCApmgAwIBAgIUXAJSjJnQYmkTx0cq7jG7bhZikh4wDQYJKoZIhvcNAQEL
BQAwaDELMAkGA1UEBhMCRlIxDjAMBgNVBAgMBVBhcmlzMRIwEAYDVQQHDAlDaGFu
dGlsbHkxDjAMBgNVBAoMBUVmcmVpMREwDwYDVQQLDAhTZWN1cml0eTESMBAGA1UE
AwwJbG9jYWxob3N0MB4XDTI1MTIyNjE0MzMyN1oXDTI2MTIyNjE0MzMyN1owaDEL
MAkGA1UEBhMCRlIxDjAMBgNVBAgMBVBhcmlzMRIwEAYDVQQHDAlDaGFudGlsbHkx
DjAMBgNVBAoMBUVmcmVpMREwDwYDVQQLDAhTZWN1cml0eTESMBAGA1UEAwwJbG9j
YWxob3N0MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAvxECGzrA5ggH
0MdrlyDsaX6MiH7jBZIiw7ana3q9ZEkxFxvZrBQjq/8N4Mzd6XJ2KhyXfSDbztd7
H+Ql6ZqBv/cVBHZShWuUjXs1F/e/OFW3lBY5WIOgWJu1/WRy0Md4+XHzs8TMQfwc
aw7V7PywBRUsrQvvFKj0Oc/erkKy//oNmhCd6vU1XHMtwfBelVKiEuvkO3kd2BvL
T9j4MhMJkaGvwLTH7ZpA1JMMYd5BQ2xzgv1+fVvmQtVHgSxIt1nKMQDl1BfB+MQc
fqvAilttiRdyop1HUFa80y2MzKZT3vfl4Ym+XRTWsALVafEwmFENEQlCCN0sGChQ
H8xTikCQhwIDAQABo1MwUTAdBgNVHQ4EFgQUaCuft+7tBAHud6zV7IecQLIcNo0w
HwYDVR0jBBgwFoAUaCuft+7tBAHud6zV7IecQLIcNo0wDwYDVR0TAQH/BAUwAwEB
/zANBgkqhkiG9w0BAQsFAAOCAQEAsV9cslc2JZVs3sgd9lV/vgxSM/9q8R/TFKYT
3IOXdTSg2FRBhxGBN8PGYbENhUMGhJYkgT0nYYzOJSnupczAYAZ6q2SfHjEHRgar
7Q2gChbLnLlmYreOPPfh4q1mNtE/HAD1+dpE2UAI03Y3vMPT5IrMmiO13vQ2ntvB
lRgWmDSaob0h+y3HSwzcY7F86MZpDRuIs1+Bj4HMK0l/wbEkCZt6NrgCM8IeX1ia
M/lvc7/fba78wGEXx7PftFzgpPPXun2swHvfOj4ye8G0ZNo8ROHgTJUFs50cZHr2
AOXMhSU0SmRHM9RvzkT1IcZGu97USFMHkG6NH+MwnMmBHRCuFg==
-----END CERTIFICATE-----
subject=C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
issuer=C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
---
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: rsa_pss_rsae_sha256
Peer Temp Key: X25519, 253 bits
---
SSL handshake has read 1505 bytes and written 1740 bytes
Verification error: self-signed certificate
---
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Protocol: TLSv1.3
Server public key is 2048 bit
This TLS version forbids renegotiation.
Compression: NONE
```

```
   a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
   v:NotBefore: Dec 26 14:33:27 2025 GMT; NotAfter: Dec 26 14:33:27 2026
 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIDsTCCApmgAwIBAgIUXAJSjJnQYmkTx0cq7jG7bhZikh4wDQYJKoZIhvcNAQEL
BQAwaDELMAkGA1UEBhMCRlIxDjAMBgNVBAgMBVBhcmlzMRIwEAYDVQQHDAlDaGFu
dGlsbHkxDjAMBgNVBAoMBUVmcmVpMREwDwYDVQQLDAhTZWN1cml0eTESMBAGA1UE
AwwJbG9jYWxob3N0MB4XDTI1MTIyNjE0MzMyN1oXDTI2MTIyNjE0MzMyN1owaDEL
MAkGA1UEBhMCRlIxDjAMBgNVBAgMBVBhcmlzMRIwEAYDVQQHDAlDaGFudGlsbHkx
DjAMBgNVBAoMBUVmcmVpMREwDwYDVQQLDAhTZWN1cml0eTESMBAGA1UEAwwJbG9j
YWxob3N0MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAvxECGzrA5ggH
0MdrlyDsaX6MiH7jBZIiw7ana3q9ZEkxFxvZrBQjq/8N4Mzd6XJ2KhyXfSDbztd7
H+Ql6ZqBv/cVBHZShWuUjXs1F/e/OFW3lBY5WIOgWJu1/WRy0Md4+XHzs8TMQfwc
aw7V7PywBRUsrQvvFKj0Oc/erkKy//oNmhCd6vU1XHMtwfBelVKiEuvkO3kd2BvL
T9j4MhMJkaGvwLTH7ZpA1JMMYd5BQ2xzgv1+fVvmQtVHgSxIt1nKMQDl1BfB+MQc
fqvAilttiRdyop1HUFa80y2MzKZT3vfl4Ym+XRTWsALVafEwmFENEQlCCN0sGChQ
H8xTikCQhwIDAQABo1MwUTAdBgNVHQ4EFgQUaCuft+7tBAHud6zV7IecQLIcNo0w
HwYDVR0jBBgwFoAUaCuft+7tBAHud6zV7IecQLIcNo0wDwYDVR0TAQH/BAUwAwEB
/zANBgkqhkiG9w0BAQsFAAOCAQEAsV9cslc2JZVs3sgd9lV/vgxSM/9q8R/TFKYT
3IOXdTSg2FRBhxGBN8PGYbENhUMGhJYkgT0nYYzOJSnupczAYAZ6q2SfHjEHRgar
7Q2gChbLnLlmYreOPPfh4q1mNtE/HAD1+dpE2UAI03Y3vMPT5IrMmiO13vQ2ntvB
lRgWmDSaob0h+y3HSwzcY7F86MZpDRuIs1+Bj4HMK0l/wbEkCZt6NrgCM8IeX1ia
M/lvc7/fba78wGEXx7PftFzgpPPXun2swHvfOj4ye8G0ZNo8ROHgTJUFs50cZHr2
AOXMhSU0SmRHM9RvzkT1IcZGu97USFMHkG6NH+MwnMmBHRCuFg==
-----END CERTIFICATE-----
subject=C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
issuer=C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
---
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: rsa_pss_rsae_sha256
Peer Temp Key: X25519, 253 bits
---
SSL handshake has read 1505 bytes and written 1740 bytes
Verification error: self-signed certificate
---
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Protocol: TLSv1.3
Server public key is 2048 bit
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 18 (self-signed certificate)
---

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ openssl s_client -connect 192.168.142.135:443 < /dev/null 2>/dev/nul
l | openssl x509 -noout -subject -issuer -dates
subject=C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
issuer=C=FR, ST=Paris, L=Chantilly, O=Efrei, OU=Security, CN=localhost
notBefore=Dec 26 14:33:27 2025 GMT
notAfter=Dec 26 14:33:27 2026 GMT

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ nmap --script ssl-enum-ciphers -p 443 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 19:19 CET
Nmap scan report for 192.168.142.135
Host is up (0.0015s latency).

PORT    STATE SERVICE
443/tcp open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_CCM (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_CCM_8 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CCM (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_CCM_8 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_ARIA_128_GCM_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_ARIA_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (dh 2048) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_128_GCM_SHA256 (rsa 2048) - A
```

```
|       TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_ARIA_128_GCM_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_ARIA_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (dh 2048) - A
|       TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA256 (dh 2048) - A
|       TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (dh 2048) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_ARIA_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_128_CBC_SHA256 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CAMELLIA_256_CBC_SHA384 (secp256r1) - A
|       TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CCM_8 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_ARIA_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_CAMELLIA_256_CBC_SHA256 (rsa 2048) - A
|     compressors:
|       NULL
|     cipher preference: client
|   TLSv1.3:
|     ciphers:
|       TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|       TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|     cipher preference: client
|_  least strength: A
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.22 seconds
```

Annexe 5

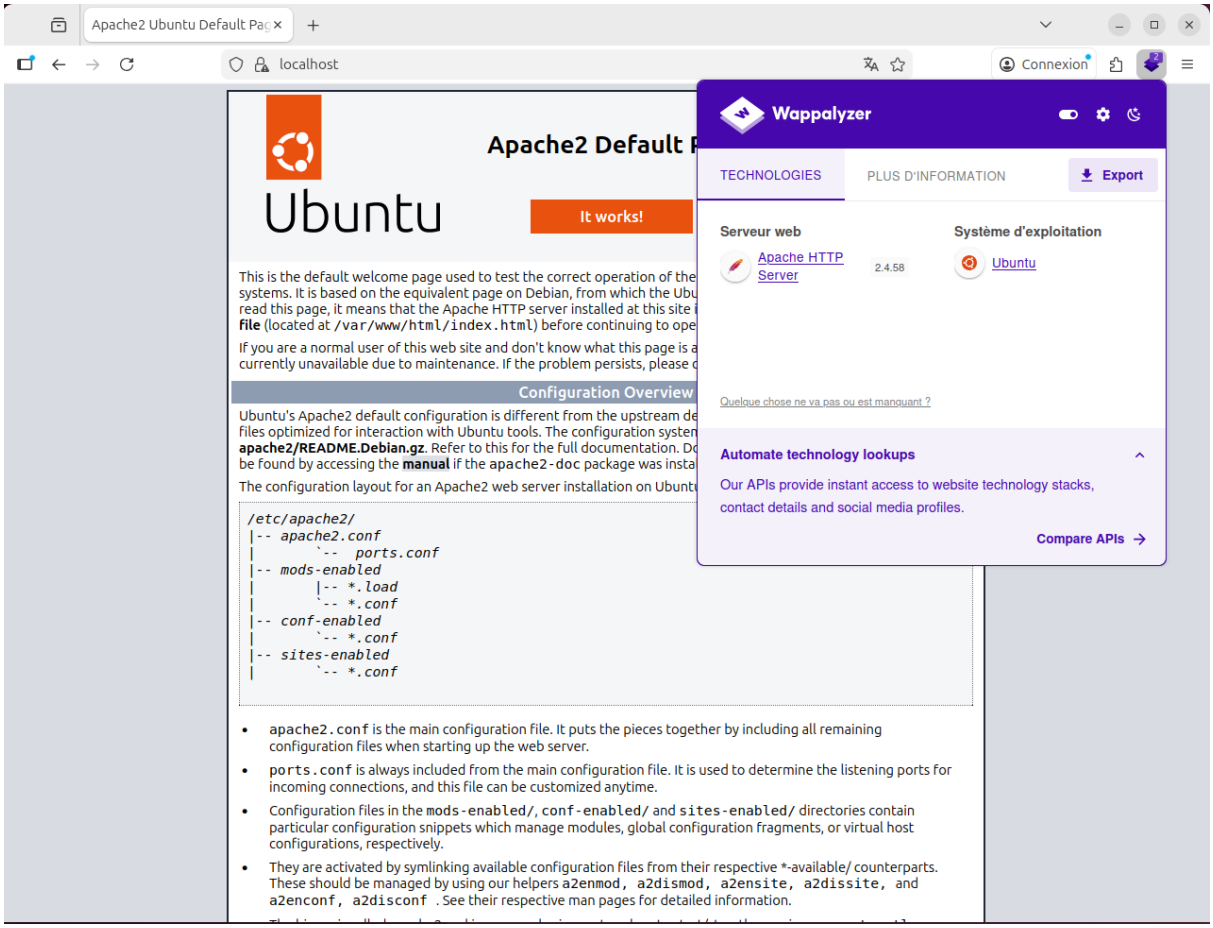
```
┌──(brandon㉿kali)-[~/Bureau]
└─$ whatweb http://192.168.142.135

http://192.168.142.135 [301 Moved Permanently] Apache[2.4.58], Country[RESERVED][ZZ], HTTPSe
rver[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], IP[192.168.142.135], RedirectLocation[https://19
2.168.142.135/], Title[301 Moved Permanently], UncommonHeaders[x-content-type-options,referr
er-policy,content-security-policy,permissions-policy], X-Frame-Options[SAMEORIGIN], X-XSS-Pr
otection[1; mode=block]
https://192.168.142.135/ [403 Forbidden] Apache[2.4.58], Country[RESERVED][ZZ], HTTPServer[U
buntu Linux][Apache/2.4.58 (Ubuntu)], IP[192.168.142.135], Title[403 Forbidden], UncommonHea
ders[x-content-type-options,referrer-policy,content-security-policy,permissions-policy], X-F
rame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block]
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ whatweb -a 3 http://192.168.142.135
http://192.168.142.135 [301 Moved Permanently] Apache[2.4.58], Country[RESERVED][ZZ], HTTPSe
rver[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], IP[192.168.142.135], RedirectLocation[https://19
2.168.142.135/], Title[301 Moved Permanently], UncommonHeaders[x-content-type-options,referr
er-policy,content-security-policy,permissions-policy], X-Frame-Options[SAMEORIGIN], X-XSS-Pr
otection[1; mode=block]
https://192.168.142.135/ [403 Forbidden] Apache[2.4.58], Country[RESERVED][ZZ], HTTPServer[U
buntu Linux][Apache/2.4.58 (Ubuntu)], IP[192.168.142.135], Title[403 Forbidden], UncommonHea
ders[x-content-type-options,referrer-policy,content-security-policy,permissions-policy], X-F
rame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block]
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ whatweb -v http://192.168.142.135
WhatWeb report for http://192.168.142.135
Status    : 301 Moved Permanently
Title     : 301 Moved Permanently
IP        : 192.168.142.135
Country   : RESERVED, ZZ

Summary   : Apache[2.4.58], HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], RedirectLocati
on[https://192.168.142.135/], UncommonHeaders[x-content-type-options,referrer-policy,content
-security-policy,permissions-policy], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=
block]

Detected Plugins:
[ Apache ]
        The Apache HTTP Server Project is an effort to develop and
        maintain an open-source HTTP server for modern operating
        systems including UNIX and Windows NT. The goal of this
        project is to provide a secure, efficient and extensible
        server that provides HTTP services in sync with the current
        HTTP standards.

        Version      : 2.4.58 (from HTTP Server Header)
        Google Dorks: (3)
        Website     : http://httpd.apache.org/

[ HTTPServer ]
        HTTP server header string. This plugin also attempts to
        identify the operating system from the server header.

        OS           : Ubuntu Linux
        String       : Apache/2.4.58 (Ubuntu) (from server string)

[ RedirectLocation ]
        HTTP Server string location. used with http-status 301 and
        302

        String       : https://192.168.142.135/ (from location)

[ UncommonHeaders ]
        Uncommon HTTP server headers. The blacklist includes all
        the standard headers and many non standard but common ones.
        Interesting but fairly common headers should have their own
        plugins, eg. x-powered-by, server and x-aspnet-version.
        Info about headers can be found at www.http-stats.com

        String       : x-content-type-options,referrer-policy,content-security-policy,permissions-policy (from headers)

[ X-Frame-Options ]
        This plugin retrieves the X-Frame-Options value from the
        HTTP header. - More Info:
```

```
[ X-Frame-Options ]
        This plugin retrieves the X-Frame-Options value from the
        HTTP header. - More Info:
        http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
        aspx

        String       : SAMEORIGIN

[ X-XSS-Protection ]
        This plugin retrieves the X-XSS-Protection value from the
        HTTP header. - More Info:
        http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
        aspx

        String       : 1; mode=block

HTTP Headers:
        HTTP/1.1 301 Moved Permanently
        Date: Sat, 27 Dec 2025 19:35:52 GMT
        Server: Apache/2.4.58 (Ubuntu)
        X-Frame-Options: SAMEORIGIN
        X-XSS-Protection: 1; mode=block
        X-Content-Type-Options: nosniff
        Referrer-Policy: strict-origin-when-cross-origin
        Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data:; font
        Permissions-Policy: geolocation=(), microphone=(), camera=()
        Location: https://192.168.142.135/
        Content-Length: 313
        Connection: close
        Content-Type: text/html; charset=iso-8859-1

WhatWeb report for https://192.168.142.135/
Status    : 403 Forbidden
Title     : 403 Forbidden
IP        : 192.168.142.135
Country   : RESERVED, ZZ

Summary   : Apache[2.4.58], HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], UncommonHeaders[x-content-type-options,referrer-policy
ions[SAMEORIGIN], X-XSS-Protection[1; mode=block]

Detected Plugins:
[ Apache ]
        The Apache HTTP Server Project is an effort to develop and
        maintain an open-source HTTP server for modern operating
        systems including UNIX and Windows NT. The goal of this
        project is to provide a secure, efficient and extensible
        server that provides HTTP services in sync with the current
        HTTP standards.

        Version      : 2.4.58 (from HTTP Server Header)
        Google Dorks: (3)
```

```
        Website     : http://httpd.apache.org/

[ HTTPServer ]
        HTTP server header string. This plugin also attempts to
        identify the operating system from the server header.

        OS           : Ubuntu Linux
        String       : Apache/2.4.58 (Ubuntu) (from server string)

[ UncommonHeaders ]
        Uncommon HTTP server headers. The blacklist includes all
        the standard headers and many non standard but common ones.
        Interesting but fairly common headers should have their own
        plugins, eg. x-powered-by, server and x-aspnet-version.
        Info about headers can be found at www.http-stats.com

        String       : x-content-type-options,referrer-policy,content-security-policy,permissions-policy (from headers)

[ X-Frame-Options ]
        This plugin retrieves the X-Frame-Options value from the
        HTTP header. - More Info:
        http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
        aspx

        String       : SAMEORIGIN

[ X-XSS-Protection ]
        This plugin retrieves the X-XSS-Protection value from the
        HTTP header. - More Info:
        http://msdn.microsoft.com/en-us/library/cc288472%28VS.85%29.
        aspx

        String       : 1; mode=block

HTTP Headers:
        HTTP/1.1 403 Forbidden
        Date: Sat, 27 Dec 2025 19:35:55 GMT
        Server: Apache/2.4.58 (Ubuntu)
        X-Frame-Options: SAMEORIGIN
        X-XSS-Protection: 1; mode=block
        X-Content-Type-Options: nosniff
        Referrer-Policy: strict-origin-when-cross-origin
        Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data:;
        Permissions-Policy: geolocation=(), microphone=(), camera=()
        Content-Length: 281
        Connection: close
        Content-Type: text/html; charset=iso-8859-1
```




```
┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -s -o /dev/null -w '%{http_code}' http://192.168.142.135/robot.txt
301

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -s -o /dev/null -w '%{http_code}' http://192.168.142.135/sitemap.xml
301

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -s -o /dev/null -w '%{http_code}' http://192.168.142.135/.htaccess
301

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -s -o /dev/null -w '%{http_code}' http://192.168.142.135/phpinfo.php
301

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -s -o /dev/null -w '%{http_code}' http://192.168.142.135/server-status
301

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ gobuster dir -u http://192.168.142.135 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.142.135
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================

Error: the server returns a status code that matches the provided options for non exis
gth: 349). To continue please exclude the status code or the length

┌──(brandon㉿kali)-[~/Bureau]
└─$
```

```
┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -I -k https://192.168.142.135 | grep -i server
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
  0 10671    0     0    0     0     0     0  --:--:-- --:--:-- --:--:--     0
Server: Apache/2.4.58 (Ubuntu)

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -I -k https://192.168.142.135 | grep -iE 'x-frame|x-xss|x-content|strict|csp'
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
  0 10671    0     0    0     0     0     0  --:--:-- --:--:-- --:--:--     0
X-Frame-Options: SAMEORIGIN
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin

┌──(brandon㉿kali)-[~/Bureau]
└─$ nmap --script http-waf-detect -p 443 192.168.142.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-27 21:10 CET
Nmap scan report for 192.168.142.135
Host is up (0.0016s latency).

PORT    STATE SERVICE
443/tcp open  https
MAC Address: 00:0C:29:65:31:05 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.94 seconds

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -k "https://192.168.142.135/?id=1' OR '1'='1"
curl: (3) URL rejected: Malformed input to a URL function

┌──(brandon㉿kali)-[~/Bureau]
└─$ curl -k "https://192.168.142.135/?id=1' OR '1'='1"
```